

Juridisk information

Datum 2019-02-08

Diarienummer RS 2019-01281

Västra Götalandsregionen

Koncernkontoret, juridiska enheten

Handläggare: Lina Kolsmyr

Telefon: 072-210 32 83

E-post: lina.kolsmyr@vgregion.se

Juridisk information om användning av molntjänster i Västra Götalandsregionen

1 Innehåll

2	Sammanfattning.....	4
3	Inledning.....	4
4	Om molntjänster	5
4.1	Vad är en molntjänst?	5
4.2	Varför molntjänster?.....	5
4.2.1	Ekonomi	5
4.2.2	Säkerhet	6
4.2.3	Uppdateringar/Underhåll	6
4.3	Typer av molntjänster	6
4.4	Hur kan man säkerställa att sekretessbelagd information inte röjs?....	6
4.4.1	Inledning.....	6
4.4.2	Kryptering.....	6
4.5	Säkerhet i molnet i jämförelse med on-premises.....	7
5	Informationen i molntjänster	8
5.1	Juridiska förutsättningar	8
5.2	Informationsklassning	8
5.3	Arkivregler.....	9
6	GDPR	10
6.1	Personuppgifter i molntjänster.....	10
6.2	Personuppgiftsbiträdesavtal.....	12
6.3	Underleverantörsfrågor.....	12
6.4	Tredjelandfrågor.....	13
7	Offentlighets- och sekretesslagen.....	13
7.1	Inledning.....	13
7.1.1	Vad avses med sekretess?.....	13
7.1.2	Vad avses med röjande?	13
7.1.3	Vilken information hos VGR omfattas av sekretess?.....	14
7.1.4	Hur tillämpas bestämmelser i offentlighets- och sekretesslagen? .	14
7.1.5	Generell menprövning	14
7.1.6	Nödvändigt utlämnande.....	15
7.2	JO-beslutet ”Conscriptor” angående avtalad sekretess	15
7.3	Andra bedömningar	16
7.3.1	Inledning.....	16
7.3.2	e-Sams första utredning	16
7.3.3	Pensionsmyndighetens ställningstagande.....	16

7.3.4	Setterwalls utredning på uppdrag av SKL	17
7.3.5	Digitaliseringsutredningen	17
7.3.6	e-Sams andra utredning	18
8	Cloud Act.....	19
8.1	Innebörd och konsekvenser av Cloud Act.....	19
8.2	Betydelsen av Cloud Act i förhållande till svensk lagstiftning	20
9	Avslutande bedömning	21

2 Sammanfattning

Denna utredning presenterar en genomgång av juridiska frågor som blir aktuella vid Västra Götalandsregionens (VGR) användning av molntjänster.

För att kunna dra slutsatser om hur tekniska lösningar samspelar med lagstiftningens krav gör utredningen till en början en genomgång av vad som avses med molntjänster och hur tekniska lösningar för att skydda informationen i molntjänster ser ut.

Därefter beskrivs grundläggande krav som gäller för all information som VGR väljer att hantera i en molntjänst. Hit hör framför allt tryckfrihetsförordningens krav på hantering av allmänna handlingar och arkivlagens regler om arkivering och gallring av allmänna handlingar. Hänvisningar görs också till styrande dokument som VGR antagit på området.

När VGR hanterar information i en molntjänst innebär detta i de flesta fall att även personuppgifter behandlas i molntjänsten. VGR är personuppgiftsansvarig för uppgifter som lagras i molnet och ansvarar för att personuppgifterna behandlas i enlighet med EU:s dataskyddsförordning GDPR. Ett särskilt avsnitt ägnas därför åt kraven i GDPR.

Den juridiskt mest komplicerade frågan att lösa vid lagring av uppgifter i molnet gäller säkerställandet av att sekretessbelagda uppgifter inte röjs på ett otillåtet sätt genom att uppgifter hanteras av en molntjänstleverantör. I avsnittet om offentlighets- och sekretesslagen diskuteras denna fråga med hänvisning till relevant lagstiftning och andra utredningar på området.

Amerikanska Cloud Act, som trädde ikraft 2018, innebär att företag som omfattas av amerikansk jurisdiktion under vissa förutsättningar kan tvingas lämna ut data till amerikanska myndigheter för brottsförebyggande arbete, oberoende av om denna data finns lagrad i USA eller utomlands. Eftersom detta kan komma i konflikt med såväl GDPR som reglerna kring sekretess vid lagring av uppgifter hos amerikanska företag görs en genomgång av innebörden av Cloud Act och dess betydelse i förhållande till svensk lagstiftning.

Avslutningsvis redovisas de slutsatser som juridiska enheten drar av det redovisade regelverket.

Utredningen har genomförts av Kompetensgrupp Personuppgifter och sekretess inom juridiska enheten på Koncernkontoret, VGR. Kompetensgruppen består av Lina Kolsmyr, Anders Falkeby, Ingrid Flodérus, Andreas Dynefors Hallberg, Astrid Helmstad och Eva-Britt Zetterström.

3 Inledning

Juridiska enheten har på senare tid fått många frågor om vad som gäller vid VGR:s användning av molntjänster. Digitaliseringen går i snabb takt med stora fördelar för offentliga aktörer. Samtidigt finns ett stort ansvar för VGR att hantera information, som i många fall är känslig, i enlighet med gällande lagstiftning. Teknikutvecklingen och lagstiftningen följs inte åt, vilket ger upphov till nya och svåra frågeställningar. Det finns en upplevelse av att myndigheter mer eller

mindre är tvingade att lägga uppgifter i molnet för att kunna använda sig av digitaliseringens möjligheter samtidigt som det finns en oro för att förlora kontrollen över känsliga uppgifter.

Detta material har arbetats fram av juridiska enheten för att beskriva den samlade juridiska nulägesbilden. Läsare av utredningen är förhoppningsvis personer inom VGR som behöver förstå de olika juridiska frågor som uppkommer i samband med molntjänster. Syftet är inte att lösa de uppkommande frågorna, utan att belysa juridiska förutsättningar för att kunna ligga till grund för dialog och ställningstagande inom VGR gällande användning av olika molntjänster.

Med tanke på den snabba teknikutvecklingen och den pågående juridiska diskussionen behöver detta dokument vara levande. Materialet kommer att uppdateras fortlöpande allteftersom tekniken utvecklas och lagstiftningen anpassas.

4 Om molntjänster

4.1 Vad är en molntjänst?

Molntjänster är IT-tjänster som tillhandahålls över internet, i synnerhet funktioner som traditionellt sköts på egna datorer men genom molnet sköts av någon annan. Det kan till exempel handla om tillämpningsprogram, serverprogram och lagring av data. Molntjänster kan delas upp i tre olika kategorier:

1. **Privat moln** innebär att VGR köper och driver och underhåller sina egna servrar och att VGR anställda kommer åt information på dessa över internet. Detta kallas också "on-premises". Kostnaderna för ett privat moln ligger helt hos VGR.
2. **Publikt moln** innebär att VGR köper utrymme på någon annans server som VGR får åtkomst till via internet. Exempel på publika moln är Microsoft OneDrive, Drop box etc. Kostnaderna för ett publikt moln delas mellan alla kunder till den aktuella molntjänsten.
3. **Community Cloud** innebär att flera organisationer (t.ex. företag eller myndigheter) tillsammans bygger en gemensam molntjänst som bara de organisationerna får tillgång till. Ett exempel på Community Cloud är Statens Servicecenter som planerar att bygga en gemensam molntjänst för alla statliga myndigheter. Kostnaderna för ett Community Cloud delas mellan de organisationer som tillsammans bygger molntjänsten.

4.2 Varför molntjänster?

4.2.1 Ekonomi

Det är betydligt dyrare att använda egna servrar än att köpa serverutrymme hos en molntjänstleverantör. Anledningen till att det blir billigare är att en stor molntjänstleverantör har skalfördelar jämfört med t.ex. VGR som är en relativt liten organisation i IT-sammanhang, dvs. VGR har ganska få servrar jämfört med t.ex. Microsoft.

- VGR behöver inte hyra lokaler att placera servrar i
- VGR behöver inte köpa servrarna

- Övriga driftskostnader för servrarna i form av t.ex. el, personal som sköter servrar, lokalvård, väktare mm. ingår i priset.

4.2.2 Säkerhet

Backup görs på geografiskt separerade servrar med olika elförsörjningsenheter etc. De stora molntjänstleverantörerna har generellt sett mycket god fysisk säkerhet.

4.2.3 Uppdateringar/Underhåll

Leverantören sköter uppdateringar av hårdvara och mjukvara när applicerbart.

4.3 Typer av molntjänster

Alla molntjänster kan bestå av följande delar.

- SaaS - Software as a service, applikationer som körs på molnet och erbjuds via internet till konsumenter, företag och myndigheter via t.ex. en webbläsare. Exempel är Facebook och Office 365 (on-line version).
- PaaS - Platform as a service, utvecklingsmiljöer som körs i molnet och erbjuds via internet till konsumenter, företag och myndigheter.
- IaaS - Infrastructure as a service, drift av servrar i molnet som erbjuds till konsumenter, företag och myndigheter över internet.
- Hybrid cloud - Blandning mellan moln (SaaS, PaaS, IaaS) och on-premises (egna servrar). Man kan t.ex. spara och hantera känslig information on-premises och mindre känslig information hos en molntjänstleverantör. Detta kräver dock att man klassificerar informationen.

4.4 Hur kan man säkerställa att sekretessbelagd information inte röjs?

4.4.1 Inledning

Vad gäller risken att molntjänstleverantören tvingas lämna ut data till annat lands myndigheter så finns det två sätt att förhindra detta.

1. Molntjänstleverantören som upphandlas är svensk utan filialer, dotterbolag etc. i annan jurisdiktion samt att deras servrar är placerade i Sverige, och/eller
2. Kryptering som gör att molntjänstleverantören endast kan läsa informationen i krypterad form, d.v.s. att molntjänstleverantören i och för sig kan tvingas att utge information, men den kommer att vara oläslig.

4.4.2 Kryptering

Vad gäller kryptering så är det som i första hand påverkar informationssäkerheten, var krypteringsnyckeln genereras och förvaras. Antingen genereras/förvaras krypteringsnyckeln hos molntjänstleverantören eller hos VGR.

- **Hold Your Own Key (HYOK)** – VGR genererar krypteringsnyckeln och behåller den i egen ägo.
- **Bring your Own Key (BYOK)** - VGR genererar krypteringsnyckeln och ger den till molntjänstleverantören.

Molntjänstleverantören kan också generera en krypteringsnyckel men då förlorar VGR möjligheten att förstöra/byta krypteringsnyckel och på så sätt säkerställa att informationen på molntjänstleverantörens servrar blir oläslig vilket kan vara

nödvändigt vid byte av molntjänstleverantör. Det finns således ingen uppenbar anledning att låta molntjänstleverantören generera krypteringsnyckel.

HYOK

Om nyckeln finns hos VGR är säkerheten högre eftersom molntjänstleverantören inte kan läsa informationen i dekrypterad form. Men, om molntjänstleverantören inte har nyckeln och således inte kan läsa informationen så kan de inte heller indexera eller köra informationen i olika program. Av denna anledning så är det inte möjligt att kombinera HYOK med SaaS (Software as a Service). Information som är HYOK-krypterad är därför mycket svårbehandlad.

BYOK

Om nyckeln finns hos molntjänstleverantören så är säkerheten sämre eftersom en icke svensk molntjänstleverantör kan tvingas utge data till utländska myndigheter samt att anställda hos molntjänstleverantören i teorin kan läsa informationen.

Kombination mellan HYOK/BYOK OCH SaaS/IaaS

Molntjänstens typ (SaaS/PaaS/IaaS) påverkar möjligheten till kryptering och i förlängningen informationssäkerheten. Här kommer endast IaaS och SaaS att diskuteras därför att de representerar ytterligheterna.

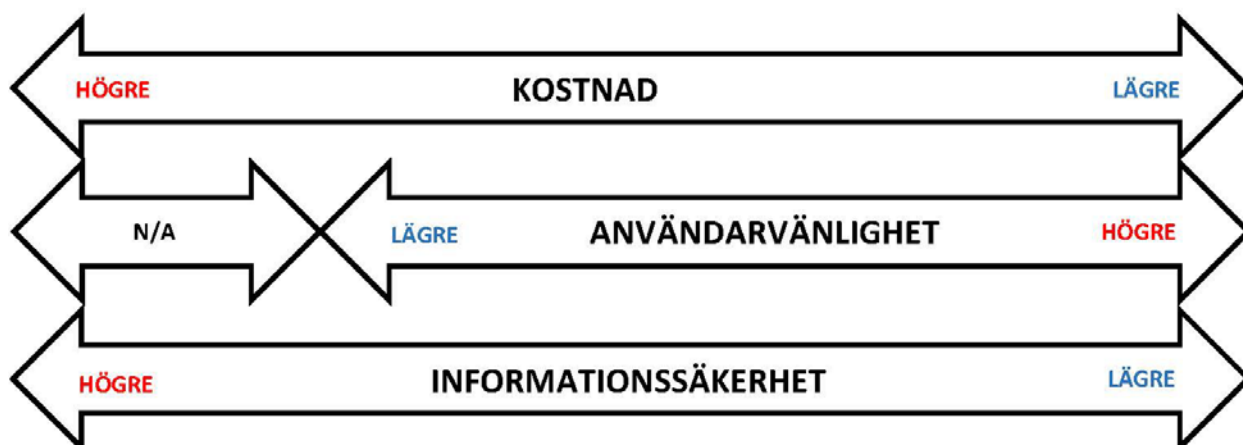
Som nämnts ovan så varierar möjligheten att använda HYOK eller BYOK beroende på vilken typ av molntjänst man väljer att använda. Därtill varierar möjligheten att använda den lagrade informationen beroende på HYOK eller BYOK. Eftersom olika kombinationer ger olika säkerhet och användarvänlighet så är det ett givet alternativ att använda en säkrare men inte så användarvänlig lösning för känslig data och en mindre säker men mer användarvänlig lösning för data som inte kräver hög säkerhet. Detta kan göras på följande sätt:

1. **On-premises + SaaS** - Servrar och krypteringsnyckel hos VGR för känslig data och SaaS+BYOK för data som är mindre känslig. På detta sätt har VGR god kontroll på känslig data samtidigt som man kan utnyttja fördelarna som finns med SaaS tjänster som t.ex. Office 365.
2. **IaaS/HYOK + SaaS/BYOK** - Känslig data läggs på en IaaS server med HYOK, mindre känslig data läggs på en SaaS server med BYOK. Fördelen med denna lösning framför (1) ovan är att man inte behöver drifta egna servrar (on-premises). Nackdelen är att data som ligger på IaaS med BYOK är svårbehandlad.

Båda lösningarna (1 & 2) kräver dock att informationen säkerhetsklassificeras vid skapandet. Det finns färdiga lösningar för detta från flera mjukvaruleverantörer.

4.5 Säkerhet i molnet i jämförelse med on-premises

Hur stark informationssäkerheten är beror på vilken/vilka molnlösning(ar) som väljs, t.ex. om Hybrid Cloud används samt hur informationen klassas. Det kan med stor sannolikhet antas att säkerhetsriskerna förändras beroende på vilka lösningar som väljs, men det går inte att avgöra om de blir fler och allvarigare eller färre och mindre allvarliga inom ramen för detta dokument.



1. HYOK	2. HYOK	3. BYOK	4. BYOK
			
On-Prem 	IaaS 	PaaS 	SaaS 
SEKRETESSDATA	SEKRETESSDATA	PUBLIK DATA	PUBLIK DATA
Hög säkerhet Hög användarvänlighet Hög kostnad	Hög säkerhet Låg användarvänlighet Lägre kostnad än (1)	Lägre säkerhet än 1-2 Högre användarvänlighet än 1-2 Lägre kostnad än 1-2	Lägre säkerhet än 1-3 Högre användarvänlighet än 1-3 Lägre kostnad än 1-3

5 Informationen i molntjänster

5.1 Juridiska förutsättningar

VGR har skyldighet att hantera information i enlighet med gällande regelverk. Vid användning av molntjänster behöver VGR kontrollera att informationshanteringen är förenlig med gällande rätt. Denna laglighetskontroll omfattar flera olika regelverk såsom bl. a. GDPR, offentlighets- och sekretesslagen och arkivlagen. Därtill kommer VGR:s beslutade policys och riktlinjer. Av betydelse vid bedömningen av lagligheten blir vilken information som behandlas, vem som behandlar informationen, hur den behandlas och var den geografiskt lagras och behandlas.

5.2 Informationsklassning

Regionfullmäktige beslutade 2018-11-27 (§ 217, RS 2018-00129) om [policy för säkerhet och beredskap](#). Därefter har regionstyrelsen fattat beslut om [riktlinjer för informationssäkerhet](#) 2018-12-11 (§349, RS 2018-00129). Enligt riktlinjerna ska nämnder och styrelser i VGR klassificera sina informationstillgångar för att avgöra lämpliga skyddsåtgärder för skydd av informationen utifrån perspektiven riktighet, konfidentialitet och tillgänglighet. Klassificering av information ska genomföras vid förändringar i organisation, i process och teknik samt vid etablering av nya IS/IT-system eller IS/IT-tjänster som kan påverka informationshanteringen.

För uppgifter där det finns särskilda lagkrav, såsom personuppgifter och sekretesskyddade uppgifter måste reglerna härom beaktas vid ställningstagande till om en molntjänst kan användas för hantering av uppgifterna. Även utan sådana krav finns dock generella krav på allmänna handlingar i tryckfrihetsförordningen (1949:105) och arkivlagen (1990:782), som måste följas.

Ny säkerhetsskyddslag (2018:585) träder ikraft den 1 april 2019 och ska enligt 1 § gälla för den som till någon del bedriver verksamhet som är av betydelse för Sveriges säkerhet eller som omfattas av ett för Sverige förpliktande internationellt åtagande om säkerhetsskydd (säkerhetskänslig verksamhet). VGR hanterar viss information som rör rikets säkerhet. Sådan information omfattas av sekretess enligt 15 kap 2 § OSL. Säkerhetsskyddslagen beskriver hur sådan information ska hanteras.

5.3 Arkivregler

VGR:s registrering, arkivering och hantering av allmänna handlingar styrs framför allt av tryckfrihetsförordningens, offentlighets- och sekretesslagens (2009:400; OSL) och arkivlagens regler. Syftet med regleringen av myndigheters allmänna handlingar är bl. a. att allmänheten ska kunna få information om myndigheters handläggning av ärenden och dess verksamhet och därigenom kunna utnyttja sina demokratiska rättigheter.

En myndighet som upphandlar en molntjänst för att hantera allmänna handlingar måste beakta arkivlagens krav på bevarande och gallring.

Enligt 3 § arkivlagen bildas en myndighets arkiv av myndighetens allmänna handlingar. Arkiven ska bevaras, hållas ordnade och vårdas, så att de tillgodoser rätten att ta del av allmänna handlingar, behovet av information för rättsskipningen och förvaltningen samt forskningens behov.

[Föreskrifter och riktlinjer om Arkiv- och informationshantering i Västra Götalandsregionen](#) har beslutats av regionfullmäktige 2017-11-21 (§ 189, RS 2017-04183) och innehåller bestämmelser om hur arkivlagen ska tillämpas i VGR.

Arkivnämnden för VGR och Göteborgs Stad är enligt föreskrifterna arkivmyndighet i VGR och beslutar om gallring. Arkivnämnden har 2018-02-07 (§ 5, RS 2018-001178) beslutat om [anvisning för Tillämpningen av föreskrifter och riktlinjer om arkiv- och informationshantering](#), som gäller för myndigheter i VGR. Därutöver behöver respektive myndighet fatta egna tillämpningsbeslut om gallring.

Gallring innebär enligt arkivnämndens definition att allmänna handlingar eller uppgifter i dessa förstörs eller aktivt avlägsnas. Gallring innefattar också åtgärder med handlingar som innebär informationsförlust, förlust av möjlighet att sammanställa information eller söka i den och förlust av möjlighet att bedöma en handlings äkthet.

En myndighet får endast gallra allmänna handlingar om det framgår av lag, förordning eller beslut av arkivmyndigheten.

Arkivnämnden har i anvisningen uttalat att användning av molntjänster och outsourcing innebär att överlämna sin informationshantering till en utomstående part. När myndigheten upphandlar en molntjänst för att hantera allmänna handlingar ska myndigheten enligt anvisningen försäkra sig om att de avtal som

tecknas med leverantören gör det möjligt att både bevara och gallra. Det ska vara möjligt att långtidsbevara handlingarna hos leverantören eller att flytta hem informationen i ett hanterbart format. Gallringen som myndigheten genomför ska också slutföras hos leverantören. Om uppgifterna fortsätter att lagras på leverantörens servrar är kravet på gallring inte uppfyllt.

VGR måste således kontrollera att avtal som tecknas med en leverantör ger förutsättningar för att både bevara de handlingar som ska bevaras och gallra de handlingar som ska gallras.

6 GDPR

EU:s dataskyddsförordning GDPR trädde i kraft i alla EU:s medlemsstater den 25 maj 2018. Det övergripande syftet är att alla medlemsstater i EU ska ha gemensamma regler för dataskydd. Av artikel 3 GDPR framgår att förordningen har ett brett territoriellt tillämpningsområde. GDPR ska tillämpas på behandling av personuppgifter inom ramen för den verksamhet som bedrivs på personuppgiftsansvarigas (PUA) eller personuppgiftsbiträdens (PUB)¹ verksamhetsställen inom unionen, oavsett om behandlingen utförs i unionen eller inte.

GDPR ställer krav på att personuppgifter behandlas enligt vissa grundläggande principer. Den princip som blir särskilt relevant när det gäller att behandla personuppgifter i molntjänster är principen om *integritet och konfidentialitet* (jfr artikel 5 f GDPR). Principen innebär att PUA har ett ansvar att skydda alla personuppgifter, så att ingen obehörig kommer åt dem och så att de inte används på ett otillåtet sätt. PUA måste även se till att personuppgifter inte förloras eller blir förstörda, till exempel genom olyckshändelser. Därför måste PUA införa lämpliga tekniska och organisatoriska säkerhetsåtgärder. Detta gäller även om VGR anlitar en extern leverantör för hantering av uppgifter, se stycke 6.2.

Till tekniska åtgärder räknas till exempel brandväggar, kryptering, pseudonymisering, säkerhetskopiering och anti-virus-skydd.

Organisatoriska åtgärder handlar till exempel om interna rutiner, instruktioner och riktlinjer.

6.1 Personuppgifter i molntjänster

Om VGR vill använda sig av molntjänster för lagring av personuppgifter innebär det att VGR utför en personuppgiftsbehandling. VGR är PUA för uppgifterna som lagras i "molnet". Därmed är det VGR:s ansvar att säkerställa att personuppgifterna behandlas i enlighet med GDPR och annan relevant lagstiftning såsom arkiv- och sekretesslagstiftning. För att kunna behandla personuppgifter i en molntjänst måste VGR göra en laglighetsprövning i vilken det bland annat ingår att pröva om uppgifterna är sekretessbelagda och därmed riskerar att röjas i strid med OSL om de läggs i molntjänster (för mer om begreppet "röjande", se nedan under avsnitt 7).

¹ Definition framgår av artikel 4 GDPR. *Personuppgiftsansvarig*: Den som bestämmer ändamålen och medlen för behandling av personuppgifter. *Personuppgiftsbiträde*: Den som behandlar personuppgifter för den personuppgiftsansvariges räkning är personuppgiftsbiträde.

Pensionsmyndigheten har på regeringens uppdrag tagit fram "[Molntjänster i staten – En ny generation av outsourcing](#)". I bilagan "Juridisk analys" görs en genomgång av den legala prövning en myndighet behöver göra vid bedömning av om det är lagligt och lämpligt att behandla en viss typ av information i en molntjänst. Utredningen är relevant också för kommunala myndigheter.

Pensionsmyndigheten konstaterar att de risker som generellt brukar aktualiseras vid behandling av personuppgifter i en molntjänst är förknippade med bristande kontroll och insyn i leverantörens behandling av personuppgifterna. En molntjänstleverantör ska därför kunna visa PUA att leverantören har rutiner för

- behörighetsstyrning, dvs. att endast de personer som behöver ta del av personuppgifterna för att kunna utföra sina arbetsuppgifter har tillgång till uppgifterna,
- tillförlitliga loggningsmekanismer,
- att bistå den personuppgiftsansvarige med att tillgodose de registrerades rätt till registerutdrag och att få rättelse, och
- att hjälpa kunden att flytta över eller hämta hem data (portabilitet).

Gällande rätt hindrar inte att en svensk vårdgivare, såvida det rör sig enbart om teknisk drift och teknisk lagring av personuppgifter, använder molntjänstleverantörer som har **fast driftställe och datacenter i Sverige**. Detta förutsätter att personuppgiftsbiträdesavtalen utformas på ett sådant sätt att de kan aktualisera att straffrättsligt skydd för uppgifterna om leverantören missbrukar eller obehörigen röjer dessa.

Många molntjänstleverantörer erbjuder sina kunder standardiserade avtalsvillkor. Därför har Datainspektionen uttalat att det är av avgörande betydelse att den personuppgiftsansvarige utför en **laglighetsprövning av avtalsvillkoren** i förhållande till den planerade personuppgiftsbehandlingen. Endast på detta sätt kan den ansvarige kontrollera om den planerade behandlingen av personuppgifter i molntjänsten är tillåten enligt lag.

Datainspektionen har uttalat att behandling av personuppgifter i molntjänster som tillhandahålls över internet av **globala molntjänstleverantörer** kan medföra vissa specifika risker som den personuppgiftsansvarige måste beakta innan en planerad behandling av personuppgifter inleds. Riskerna hänför sig framför allt till bristande kontroll över de personuppgifter som behandlas i molntjänsten och bristande insyn i personuppgiftsbitrådets behandling av personuppgifterna ifråga. Datainspektionen anger att för att en personuppgiftsansvarig ska kunna bedöma om det är möjligt att behandla personuppgifter i en molntjänst måste den ansvarige först genomföra en grundlig **risk- och sårbarhetsanalys**. Analysen ska genomföras bland annat med beaktande av vilka personuppgifter som ska behandlas och vilken säkerhet molntjänstleverantören erbjuder. Därefter måste den ansvarige kontrollera om det, i förhållande till GDPR och/eller annan tillämplig integritetsskyddslagstiftning, är tillåtet att behandla personuppgifter i molntjänsten, en så kallad **laglighetsprövning** (jfr [Datainspektionens tillsynsbeslut mot Ale kommun den 25 april 2014 i dnr 1475-2013](#)).

Som personuppgiftsansvarig ska VGR ta hänsyn till

- vilka säkerhetsåtgärder som ska vidtas för att skydda de personuppgifter som behandlas
- om uppgifterna är skyddade av någon sekretessbestämmelse i OSL
- om det finns risk för att personuppgifter kan komma att behandlas för andra ändamål än de ursprungliga,
- Om ”molnet” (dvs serverhallen) finns i tredje land krävs även att **tredjelandsoverföring har stöd i GDPR** ([se juridisk information om tredjelandsoverföring](#)).

6.2 Personuppgiftsbiträdesavtal

Syftet med personuppgiftsbiträdesavtal (PUB-avtal) är att ge garantier för att säkerhet och sekretess för personuppgifter inte försämrats till följd av att PUA väljer att anlita ett PUB i stället för att själv utföra behandlingen av personuppgifter. Ett personuppgiftsbiträde är en osjälvständig part i förhållande till den personuppgiftsansvarige och får bara behandla personuppgifterna i enlighet med de instruktioner som PUA har utfärdat för uppdraget.

Datainspektionen har i sina granskningar funnit brister i personuppgiftsbiträdesavtal som tillhandhålls av molntjänstleverantörer. Bristerna har bl.a. varit hänförliga till avtalsvillkor som har varit alltför svårtolkade och otydligt formulerade. Enligt Datainspektionen har avtalsvillkoren bl.a. lämnat utrymme för molntjänstleverantören att behandla den ansvariges personuppgifter för egna ändamål och saknat fastställda tidsramar för molntjänstleverantörens radering av personuppgifterna (jfr Datainspektionens beslut den 31 maj 2013, [dnr 1351-2012](#) och den 10 juni 2014, [dnr 358-2014](#)).

En [ny mall för personuppgiftsbiträdesavtal](#) publicerades den 18 december 2018. Mallen är framtagen gemensamt för SKL, SKL Kommentus och Inera AB och syftar till att vara en branschstandard som alla tjänstleverantörer ska använda i PUB/PUA-situationer med kommuner och regioner som deltagande part. Det nya avtalet har framtagits i dialog med Svenskt näringsliv, branschorganisationer och leverantörer. Enhet juridik rekommenderar att VGR använder SKL-mallen vid tecknandet av PUB-avtal.

6.3 Underleverantörsfrågor

Molntjänstleverantören och **alla dess underleverantörer** är personuppgiftsbiträden till den personuppgiftsansvarige. Ansvar för att säkerhetsåtgärderna faktiskt vidtas vilar på VGR i egenskap av PUA. Därför måste VGR kunna kontrollera att samtliga underleverantörer verkligen vidtar de säkerhetsåtgärder som har avtalats eller som den ansvarige på annat sätt har lämnat instruktioner om. VGR måste därför försäkra sig om att det finns möjlighet att följa upp att samtliga biträden vidtar de säkerhetsåtgärder som krävs.

Datainspektionen har uttalat att oavsett vilken ställning underleverantören har måste personuppgiftsbiträdet tillhandahålla information om vilka bolag som är underleverantörer, var de är lokaliserade och deras huvudsakliga uppgift. Sådan information är avgörande för transparensen i avtalsförhållandet.

PUA måste också se till att avtalsvillkoren i PUB-avtalet ger förutsättningar **för kontroll av samtliga personuppgiftsbiträden.**

6.4 Tredjelandfrågor

GDPR ställer krav på att samtliga medlemsstater (och EES-stater) har ett likvärdigt skydd för personuppgifter. Därför kan personuppgifter fritt överföras mellan dessa länder utan några begränsningar av GDPR. Utanför EU finns däremot inga generella regler som ger motsvarande garantier.

GDPR innehåller ett antal undantagsregler som under vissa förutsättningar gör det tillåtet att föra över personuppgifter till länder utanför EU (tredjelandsoverföring). När personuppgifter behandlas av molntjänstleverantörer/personuppgiftsbiträden i ett land utanför EU måste den personuppgiftsansvarige därför se till att något av **undantagen från förbudet mot överföring till tredje land** är tillämpligt.

Se [juridisk information om tredjelandsoverföring](#) för en mer utförlig genomgång av vad som krävs för att kunna behandla personuppgifter i tredje land.

7 Offentlighets- och sekretesslagen

7.1 Inledning

7.1.1 Vad avses med sekretess?

Enligt 1 kap. 1 § stycke 2 OSL gäller lagen ”... förbud att röja uppgift, vare sig detta sker muntligen, genom utlämnande av allmän handling eller på något annat sätt.” Sekretess definieras i 3 kap. 1 § OSL som att förbud gäller för att röja uppgiften. Sekretess gäller både för uppgifter i handlingar som är allmänna handlingar enligt tryckfrihetsförordningen, men även för uppgifter som inte finns i allmänna handlingar, t.ex. i intern kommunikation eller arbetsmaterial. Även uppgifter som inte är skriftligen dokumenterade omfattas av sekretess. Enligt 7 kap. 1 § OSL gäller förbud enligt denna lag mot att röja en uppgift och uppgiften får inte heller i övrigt utnyttjas utanför den verksamhet för vilken den är sekretessreglerad.

Att bryta sekretessen definieras i 8 kap. 1 § OSL som att ”En uppgift för vilken sekretess gäller enligt denna lag får inte röjas för enskilda eller för andra myndigheter, om inte annat anges i denna lag eller i lag eller förordning som denna lag hänvisar till.”

En person som är anställd vid myndigheten eller som har ett uppdrag för myndigheten och som därigenom kan anses delta i en myndighets verksamhet omfattas av sekretess vid den myndigheten, och då denne får del av sekretessbelagd information utgör detta inte ett röjande (2 kap. 1 § OSL).

7.1.2 Vad avses med röjande?

I OSL finns det ingen uttalad definition av vad som avses med röjande. Ett röjande anses dock ha skett redan genom att en utomstående har fått tillgång till uppgifterna. Huruvida denne rent faktiskt har tagit del av innehållet saknar

betydelse. Ett röjande är förbjudet oavsett anledning till att det sker, vilket innebär att även rena misstag medför att uppgiften är röjd enligt OSL. Ett röjande sker inte bara om en sekretessbelagd handling aktivt överlämnas till en utomstående. Även tillgängliggörande vid myndigheten eller andra former av överlämnande utgör ett röjande. Ett röjande har skett oavsett på vilket sätt det sker (prop. 1979/80:2 Del A, s. 119 f). Ett röjande anses dock inte ha skett om uppgiften tillhandhållits för en utomstående på ett sådant sätt att det förefaller osannolikt att mottagaren tar del av uppgifterna (se e-sam och SOU 2015:66).

Den som olovligen röjer en sekretessbelagd uppgift kan dömas för brott mot tystnadsplikten enligt 20 kap. 3 § brottsbalken (BrB). Det finns så vitt känt ingen vägledande rättspraxis där begreppet ”röjer” i denna bestämmelse har prövats. I rättsfallet NJA 1991 s 103 har högsta domstolen (HD) tagit ställning till innebörden av begreppet ”röjer uppgift” i 19 kap. 9 § BrB som gäller brottet vårdslöshet med hemlig uppgift. I målet har HD kommit fram till att för att ett röjande ska anses ha skett måste uppgiften ha blivit tillgänglig för någon utomstående under sådana omständigheter att man måste räkna med att den obehörige kommer att ta del av uppgifterna.

7.1.3 Vilken information hos VGR omfattas av sekretess?

Stora delar av den information som VGR lagrar innehåller sekretessbelagda uppgifter. Inom vården gäller i princip sekretess för alla uppgifter om enskilda patienter enligt 25 kap. 1 § OSL. Även inom andra verksamheter förekommer sekretessbelagda uppgifter, t.ex. rörande upphandlingar enligt LOU enligt 19 kap. 3 § OSL eller privata uppgifter om anställda enligt 39 kap. 3 § OSL.

Inom VGR:s förvaltningar används även IT-system som i många fall kan komma att innehålla sekretessbelagda uppgifter, t.ex. i e-postsystem eller olika typer av ärendehanteringssystem. Även dessa system kan i många fall komma att innehålla sekretessbelagd information, även om de från början inte är framtagna för detta.

7.1.4 Hur tillämpas bestämmelser i offentlighets- och sekretesslagen?

En sekretessregel kan ha ett rakt eller omvänt skaderekvisit. Rakt skaderekvisit innebär att uppgifterna är offentliga om det inte kan antas att det skulle innebära skada eller men om handlingen lämnas ut. Omvänt skaderekvisit innebär att uppgifterna bara får lämnas ut om det står klart att detta inte skulle innebära skada eller men. Sekretess kan även vara absolut, vilket innebär att uppgiften aldrig får röjas, utan att någon menprövning ska göras. Om det vid en menprövning bedöms att en handling inte kan lämnas ut (eller om absolut sekretess råder) kan uppgiften endast röjas om det finns en uttalad sekretessbrytande regel.

7.1.5 Generell menprövning

Enligt vad som anförts ovan kan myndigheten göra en bedömning i det enskilda fallet av huruvida det skulle innebära skada eller men för den enskilde om uppgift om denne lämnas ut. Det är då även möjligt för en myndighet att göra en generell menprövning (schabloniserad menprövning) och bedöma att ett stort antal uppgifter kan lämnas ut utan att detta innebär skada eller men för någon av de enskilda. Generell menprövning är dock svårt att motivera för de mycket stora mängder sekretessbelagd information som skulle lämnas ut vid användande av molntjänster. Det kommer bli svårt för VGR att, med tillämpning av t.ex. 25 kap. 1 § OSL angående sekretess inom hälso- och sjukvården, visa att ingen av de

patienter som omfattas skulle lida men av att uppgifter om deras hälsa röjs till extern part.

7.1.6 Nödvändigt utlämnande

För det fall det inte går att göra en generell menprövning och därvid lämna ut uppgifterna enligt ovan kan prövning göras utifrån en sekretessbrytande regel i OSL. Den sekretessbrytande regel som skulle kunna aktualiseras vad gäller utlämnande av information till privat bolag för lagring i moln är i första hand OSL 10 kap 2 §:

”Sekretess hindrar inte att en uppgift lämnas till en enskild eller till en annan myndighet, om det är nödvändigt för att den utlämnande myndigheten ska kunna fullgöra sin verksamhet.”

Denna sekretessbrytande bestämmelse skall dock tillämpas restriktivt, och det räcker inte att ett utlämnande förenklar myndighetens fullgörande av sin verksamhet, utan måste vara nödvändigt för fullgörandet. I SOU 2018:25 bedömer utredaren att det är allt för långtgående att tolka den aktuella bestämmelsen som att extern lagring av information är nödvändig för myndigheter.

Vad gäller lagring av information finns det i dag fullt fungerande lösning för lagring av digital information inom VGR, och även om det skulle innebära både en kostnadsbesparing och förenkla hanteringen av information, så är det inte helt nödvändigt för att regionen skall kunna fullgöra sina uppgifter.

7.2 JO-beslutet ”Conscriptor” angående avtalad sekretess

Tidigare har det ansetts, med stöd av vissa förarbetsuttalanden till äldre sekretesslagen, att myndigheter kan lämna ut sekretessbelagda uppgifter till privata bolag om dessa är bundna av sekretess enligt parternas avtal, och att personal vid det privata bolaget i sin tur varit bundna av sekretess gentemot sin arbetsgivare. Justitieombudsmannen (JO) har i beslut den 9 september 2014, [dnr 3032-2011](#) tagit ställning till huruvida det har varit möjligt för VGR eller annan vårdgivare att lämna ut patientinformation till ett privat bolag som tillhandahåller tjänster av läkarsekreterare. JO gjorde följande bedömning.

”Läkarsekreterarna har en avtalsreglerad tystnadsplikt i förhållande till arbetsgivaren (dvs. företaget). Vidare följer av regelverket om behandling av personuppgifter en sorts tystnadsplikt för den som behandlar uppgifterna. Enligt JO är dessa ”alternativa” tystnadsplikter för läkarsekreterarna inte tillräckliga för att anse att ett utlämnande kan ske utan att det innebär men (skada) för den som skyddas av sekretessen. Vid bedömningen har – mot bakgrund av att de uppgifter som behandlas enligt avtalen är av mycket integritetskänsligt slag – vikt lagts bl.a. vid att vårdgivarens egen personal kan dömas för brott mot tystnadsplikt om en sekretessbelagd uppgift felaktigt röjs, medan så inte är fallet när det gäller läkarsekreterare som är anställda i företaget. Ett utlämnande har inte heller haft stöd i någon av de sekretessbrytande bestämmelser som finns i 10 kap. OSL eller i en lag eller förordning som OSL hänvisar till.

JO:s slutsats är att vårdgivarna inte har haft rättsligt stöd för att på det sätt som skett lämna ut sekretessbelagda uppgifter om patienter för journalföring av företagets läkarsekreterare. Enligt JO är det anmärkningsvärt att vårdgivarna inte har ägnat sekretessaspekterna större uppmärksamhet i samband med att avtalen

ingicks. Vårdgivarna får allvarlig kritik för att de har ingått avtal som innebär att landstinget/regionen lämnar ut patientuppgifter för journalföring av anställda vid ett företag, trots att detta inte är förenligt med regelverket om sekretess.”

7.3 Andra bedömningar

7.3.1 Inledning

Frågan om huruvida det är möjligt för offentliga organ att använda molnstjänster för hantering av sekretessbelagd information har utretts i olika sammanhang av andra organisationer.

7.3.2 e-Sams första utredning

eSam är ett samverkansprojekt mellan ett antal myndigheter och SKL, som har till uppgift att underlätta och påskynda digitaliseringen av det offentliga Sverige. Den 17 december 2015 antog e-sams expertgrupp ett uttalande angående [”Röjandebegreppet enligt offentlighets- och sekretesslagen”](#) som berörde användningen av molntjänster. I uttalandet angav expertgruppen följande:

”Om uppgifter görs tekniskt tillgängliga för en tjänsteleverantör som enligt avtalet inte får ta del av eller vidarebefordra uppgifterna och omständigheterna i övrigt medför att det är osannolikt att detta ändå sker, ska uppgifterna enligt expertgruppens bedömning inte anses som röjda i offentlighets- och sekretesslagens mening.”

7.3.3 Pensionsmyndighetens ställningstagande

Pensionsmyndigheten har på uppdrag av regeringen utrett förutsättningarna för myndigheter att använda sig av molntjänster. I sin rapport gör [Pensionsmyndigheten](#) följande sammanfattande bedömning av sekretessfrågan:

”Oavsett vilken typ av it-leverantör som anlitas av en myndighet ska myndighetens fokus vara att skydda den information som hanteras och säkerställa att informationen hanteras på ett lagligt sätt. Offentlighets- och sekretesslagstiftningen ska, utöver att skydda allmänna intressen, skydda den enskilde mot skada och men som kan uppstå om sekretessbelagda uppgifter röjs. Integritetsskyddslagstiftningen ska skydda den enskilde mot kränkning av den personliga integriteten. Arkivlagstiftningen ska säkerställa att den enskilde kan utöva sina demokratiska rättigheter genom att kunna ta del av myndighetens information och få insyn i dess verksamhet. Avtalsvillkoren mellan myndigheten och molntjänstleverantören ska säkerställa att myndigheten kan uppfylla samtliga krav som lagstiftningen ställer när informationen hanteras i en molntjänst.

Enligt vår uppfattning är den lagstiftning som aktualiseras, vid hantering av myndighetsinformation i en molntjänst, i och för sig ändamålsenlig i förhållande till ett av sina syften nämligen att värna om den enskildes rättigheter. Det sammantagna regelverket är dock omfattande, komplext och svårt för myndigheterna att tillämpa. Vidare kan det konstateras att offentlighets- och sekretesslagen kan utgöra ett hinder för myndigheter att anlita inte bara molntjänstleverantörer, utan alla typer av privata leverantörer som tillhandahåller it-tjänster. Sekretessreglerade uppgifter som t.ex. är av särskilt integritetskänsligt slag får inte lämnas ut till en utomstående aktör med mindre än att denne är bunden av en lagreglerad tystnadsplikt. Mot denna bakgrund anser vi att det finns anledning att se över möjligheten att införa en lagreglerad tystnadsplikt för dem som i sitt arbete hos privata it-leverantörer tar del av myndigheters uppgifter. En

sådan tystnadsplikt skulle kunna medföra att myndigheterna, när det i övrigt är lämpligt, i större utsträckning kan anlita privata it-leverantörer.”

7.3.4 Setterwalls utredning på uppdrag av SKL

Sveriges Kommuner och Landsting (SKL) har publicerat en utredning ”*Rättsutredning Frågor om röjande vid användning av molntjänster*”, vilken har tagits fram av advokatfirman Setterwalls. Utredningen gäller molntjänster generellt, men är inriktad mot användning av Microsoft Office 360. Utredningens slutsats är följande vad gäller bedömning av om sekretessbelagda uppgifter kan lagras i en molntjänst:

”Det är inte möjligt att lägga ut it-drift till en molntjänstleverantör av berört slag utan att tillgängliggörandet av uppgifter för leverantör omfattas av så rigorösa skydd att det måste anses osannolikt att någon obehörig kommer att ta del av eller vidarebefordra uppgifterna. Uppfylls detta krav torde inget röjande ske och därmed behöver inte heller någon tillämplig sekretessbrytande regel finnas. Vår genomgång har emellertid visat att det finns ett antal risker som – även om de i det enskilda fallet framstår som begränsade – måste beaktas från ett helhetsperspektiv. Frågan blir om det går att få del av det underlag som krävs för att kunna göra en tillräcklig prövning av risken för röjande vid en anslutning till en molntjänst av berört slag (Office 365) och hur en mindre aktör ska få tillgång till de resurser och den kompetens som krävs för att göra en sådan analys. Samordnade åtgärder behöver sannolikt vidtas för att det i praktiken ska bli möjligt att påverka utformningen av och avtalsvillkoren för en tjänst av här berört slag i nödvändiga delar. Det är rimligt att acceptera argumenten att den publika molntjänstens karaktär medför att väsentliga delar av avtalsvillkoren måste vara enhetliga och gemensamma för samtliga kunder. Detta utgör dock inget skäl för att villkoren ska vara svåröverskådliga och svåra att tillgodogöra sig. Offentlig sektor har en stark ”köpkraft” och det borde inom ramen för en gemensam och samordnad upphandling vara möjligt att påverka utformningen av avtalsvillkoren som är väsentliga för offentlig sektor i vart fall i de delar som är väsentliga för att underlätta en riskbedömning.”

7.3.5 Digitaliseringsutredningen

Regeringen beslutade den 24 november 2016 att ge en särskild utredare i uppdrag att kartlägga och analysera i vilken utsträckning det förekommer lagstiftning som i onödan försvårar digital utveckling och samverkan inom den offentliga förvaltningen. Uppdraget gavs bl.a. mot bakgrund av JO:s beslut i det så kallade Conscriptor-fallet, samt de reaktioner som kommit på detta.

Digitaliseringsutredningen ([SOU 2018:25](#)) gäller en lång rad frågor kring digitalisering inom offentlig sektor. Vad som är av intresse här är i första hand frågor gällande anlitan av privata bolag för lagring av sekretessbelagd information.

Utredningens slutsats är att det är osäkert och omtvistat huruvida det finns rättsliga förutsättningar för att under vissa omständigheter lämna ut sekretessbelagda uppgifter för extern lagring utan att ett röjande av uppgifterna faktiskt sker (SOU 2018:25 sidan 349). Till följd av detta anser utredningen att ”Det finns behov av att klargöra de rättsliga förutsättningarna för utkontraktering av it-drift och andra it-baserade funktioner från myndigheter till privata leverantörer. Detta skulle undanröja en rättslig osäkerhet som nu hindrar eller hämmar digitaliseringen och möjliggöra en effektivare offentlig sektor.”

Utifrån denna bedömning föreslår utredningen följande:

”Det finns behov av en sekretessbrytande bestämmelse för att myndigheter i samband med utkontraktering av it-drift eller andra it-baserade funktioner ska kunna lämna ut vissa sekretessbelagda uppgifter till privata eller offentliga leverantörer. En sådan sekretessbrytande bestämmelse ska införas i offentlighets- och sekretesslagen.” och innebär att ”Den som på grund av anställning eller uppdrag hos en privat leverantör tekniskt bearbetar eller tekniskt lagrar uppgifter för en myndighets räkning, får inte obehörigen röja eller utnyttja dessa uppgifter.”

Sekretess ska inte hindra att en uppgift lämnas ut till en enskild eller till en annan myndighet som utför uppdrag för enbart teknisk bearbetning eller teknisk lagring för den utlämnande myndighetens räkning, om uppgiften behövs för att utföra uppdraget. En uppgift ska inte lämnas ut om 1. övervägande skäl talar för att det intresse som sekretessen ska skydda har företräde framför intresset av att uppgiften lämnas ut, eller 2. det av andra skäl är olämpligt.

En författningsreglerad tystnadsplikt med en anknytande sekretessbrytande bestämmelse syftar inte till att bli ett frikort för utkontraktering av känslig informationshantering. Även om sekretesslagstiftningen medger ett utlämnande av uppgifter kan ett sådant utlämnande i vissa fall betraktas som olämpligt ur informationssäkerhetssynpunkt. En utkontraktering får aldrig innebära att uppgifterna får ett sämre skydd ur informationssäkerhetssynpunkt än om de hade hanterats internt hos myndigheten.

Enligt utredningens förslag ska de nya reglerna träda i kraft den 1 juli 2019. Förslaget, som varit föremål för remissförfarande, har dock än så länge inte lett till någon proposition.

7.3.6 e-Sams andra utredning

Inom eSam finns en juridisk expertgrupp som har tagit fram ett [rättsligt uttalande om röjande och molntjänster](#). I uttalandet beskriver de sin tolkning av gällande rätt i frågan. Expertgruppen bedömer att det inte går att utesluta att en leverantör av en molntjänst som lyder under utländsk lagstiftning kan medverka till att sekretessreglerade uppgifter röjs.

Expertgruppen anser att det i juridisk mening måste ses som ett röjande om en molntjänst används för behandling av uppgifter som är sekretessreglerade, och om molntjänsten ägs av ett utländskt företag där detta lands rättsordning ålägger företaget att under vissa förhållanden överlämna viss information till det landets myndigheter.

”Om sekretessreglerade uppgifter görs tekniskt tillgängliga för en tjänsteleverantör som till följd av ägarförhållanden eller annars är bunden av regler i ett annat land, enligt vilka tjänsteleverantören kan bli skyldig att överlämna information utan att internationell rättshjälp anlitas eller annan laglig grund föreligger enligt svensk rätt, får uppgifterna anses vara röjda. Anledningen är att det inte längre är osannolikt att uppgifterna kan komma att lämnas ut utomstående. Detsamma får anses gälla om redan ägarförhållanden eller geografisk placering av en tjänsteleverantörs tekniska hjälpmedel ger anledning att befara att mänskliga rättigheter (till exempel skyddet för privatlivet) eller det allmännas intressen (t.ex. rikets säkerhet) inte skulle säkerställas om svenska myndigheters data hade tillgängliggjorts.”

Det som i första hand talar för att uppgifter inte kan anses röjda vid anlitan­de av molntjänst är att själva syftet med utlämnandet inte är att mottagaren ska ta del av eller använda sig av den sekretessbelagda informationen, utan endast att denne tekniskt ska lagra informationen. Bolaget kan även bindas av avtalad tystnadsplikt. Detta talar för att den bedömning som eSam har gjort kommer bli gällande och att vissa typer av molntjänster kommer tillåtas. Mot detta talar att JO i Conscriptorfallet har gjort en hård bedömning av sekretessreglerna, och gjort en bokstavstolkning av lagtext och förarbeten.

8 Cloud Act

8.1 Innebörd och konsekvenser av Cloud Act

Det är inte ovanligt att svenska företag och myndigheter ingår avtal med tjänsteleverantörer av IT-tjänster som omfattas av amerikansk jurisdiktion. Den amerikanska lagen the Clarifying Lawful Overseas Use of Data Act (härefter Cloud Act), trädde i kraft den 23 mars 2018 och innebär att företag som omfattas av amerikansk jurisdiktion under vissa förutsättningar kan tvingas lämna ut data till amerikanska myndigheter för brottsförebyggande arbete. Cloud Act medför bland annat att en leverantör av elektronisk kommunikationstjänst eller fjärrtjänst kan tvingas tillgängliggöra data för den amerikanska staten oberoende av om denna data finns lagrad i USA eller utomlands.

En konsekvens av lagstiftningen är att amerikanska företag ges möjlighet att motsätta sig utlämnande till amerikanska myndigheter genom att USA ingår så kallade ”executive agreements” med andra länder. Avtal som ingås med stöd av Cloud Act ingås mellan det amerikanska justitiedepartementet och en annan stat. Avtalet innebär att den andra staten får statusen som ett så kallat ”kvalificerat främmande land” (*engelska* ”qualifying foreign government”). Ett kvalificerat främmande land är ett land som har bedömts dela de åtaganden som gäller enligt amerikansk rätt vad gäller lag och rätt i största allmänhet samt vad gäller rättigheter i fråga om integritet och civila rättigheter (*engelska* shares “a common commitment to the rule of law and the protection of privacy and civil liberties”). Om amerikanska myndigheter begär ut data som hänför sig till en person som är bosatt i ett kvalificerat främmande land ger avtalet amerikanska företag rätten att motsätta sig ett sådant utlämnande om utlämnandet skulle stå i strid med detta lands dataskyddslag. Möjligen kan den amerikanska staten också komma att ingå ”executive agreements” även med sammanslutningar av länder/stater. Utifrån en sådan tolkning av reglerna skulle det kunna vara tänkbart med ett avtal mellan USA och exempelvis EU. Något sådant avtal mellan Sverige och USA eller mellan EU och USA finns dock för närvarande inte.

En annan konsekvens av Cloud Act är att lagen förenklar processen för brottsbekämpande samarbete mellan stater. Cloud Act innebär att det är enklare för ett kvalificerat främmande land att få ut information från elektroniska tjänsteleverantörer i USA. EU-kommissionen arbetar med att implementera sådana åtgärder som syftar till att underlätta samarbete med amerikanska myndigheter. Detta antyder att vi i framtiden har att vänta ett ökat samarbete mellan EU och USA i fråga om datadelning, elektroniska bevis och brottsförebyggande arbete.

8.2 Betydelsen av Cloud Act i förhållande till svensk lagstiftning

Utanför EU kan man inte vara säker på att det finns regler som ger motsvarande skydd som GDPR när det gäller skyddet för personuppgifter. GDPR innehåller detaljerade regler som klargör vad som krävs för att man ska få föra över personuppgifter till länder utanför EU.

I följande fall är överföring av personuppgifter utanför EU tillåten:

1. Adekvat skyddsnivå

Innebär att det finns ett beslut från EU-kommissionen att ett visst land utanför EU säkerställer så kallad adekvat skyddsnivå. Vilka länder som bedöms ha adekvat skyddsnivå framgår av EU-kommissionens lista. *Observera att USA inte finns med på listan över säkra länder.*

2. Lämpliga skyddsåtgärder

EU-kommissionens standardavtalsklausuler (Standard Contractual Clauses). Går ut på att genom särskilda avtal binda motparten till att följa GDPR:s krav vid överföring/hantering av personuppgifter. EU har tagit fram mallar för standardavtalsklausuler som ska användas

Bindande företagsbestämmelser (Binding Corporate Rules). En kvalitetsstämpel där vissa koncerner med bolag som är verksamma i flera länder har genomgått en procedur och blivit godkända av EU-kommissionen. EU har en lista över godkända företag.

3. Särskilda situationer och enstaka överföringar

Undantagsregel som ger rätt att i särskilda situationer föra över personuppgifter till ett land utanför EU. Ska användas restriktivt.

USA är inte ett land som uppfyller adekvat skyddsnivå enligt GDPR. Enligt beslut från EU-kommissionen är det dock tillåtet för personuppgiftsansvariga i EU att överföra personuppgifter till mottagare som har anslutit sig till det så kallade **Privacy Shield**. Privacy Shield är en mekanism för självcertifiering som innebär att företag/organisationer i USA kan anmäla sig till det amerikanska handelsdepartementet och meddela att de uppfyller de krav som ställs i Privacy Shield. Observera att detta inte gäller för USA som helhet utan endast sådana amerikanska företag som anslutit sig till Privacy Shield.

För att VGR ska kunna lagra personuppgifter i en molntjänst som omfattas av amerikansk jurisdiktion måste tjänsteleverantören omfattas av Privacy Shield alternativt att VGR har vidtagit några av de skyddsåtgärder som räknas upp i GDPR artikel 46. En av dessa skyddsåtgärder är kommissionens standardavtalsklausuler. I dessa klausuler är avtalspartnern i det tredje landet bland annat skyldig att informera om eventuell lokal lagstiftning som skulle ha en betydande

negativ inverkan på de garantier som ges enligt dessa klausuler. Cloud Act skulle kunna vara en sådan lagstiftning.

Utöver skyddsåtgärderna i artikel 46 finns det en bestämmelse i GDPR artikel 48 som innebär att vissa tredjelandsoverföringar som har sin grund i avtal om ömsesidig rättshjälp är lagliga. Enligt artikeln får beslut av en domstol eller myndigheter i tredjeland om utlämnande erkännas om beslutet grundar sig på en internationell överenskommelse såsom ett avtal om ömsesidig rättshjälp. Det som i den svenska versionen av GDPR benämns som ett "avtal om ömsesidig rättshjälp" motsvaras av det engelska begreppet "mutual legal assistance treaty". Det är högst oklart om de internationella avtal/överenskommelser som ingås med stöd av Cloud Act kan klassificeras som ett sådant avtal om ömsesidig rättshjälp, sannolikt inte.

När det gäller reglerna kring sekretess skulle enligt vad som tidigare anförts hantering av uppgifter i en molntjänst kunna innebära att röjande av uppgifterna anses ha skett. eSams juridiska expertgrupp har i sitt rättsliga uttalande om molntjänster (se avsnitt 7.3.6) framfört att utlämnande till ett företag som omfattas av lagstiftning likt den amerikanska Cloud Act innebär ett röjande. Samtidigt menar eSam att "en annan bedömning kan visserligen inte uteslutas för det fall att ett röjande hindras genom kryptering av tillräcklig – och när så krävs godkänd – kvalitet eller av andra åtgärder med samma verkan." Molntjänstens tekniska beskaffenhet och i vilket "skick" uppgifterna lämnas ut (om de exempelvis är pseudonymiserade eller inte) påverkar bedömningen om röjande enligt reglerna om sekretess.

Sammanfattningsvis får Cloud Act betydelse för efterlevnaden av svensk lagstiftning. Cloud Act kan komma i konflikt med såväl GDPR som reglerna kring sekretess. De avtal stater kan ingå genom Cloud Act är inte sådana som GDPR tillåter. Vidare anses med stor sannolikhet uppgifter som hanteras av ett företag som lyder under Cloud Act röjda enligt OSL:s mening.

Andra länders lagstiftning har inte undersökts. Det är inte osannolikt att även andra länder än USA har liknande reglering om krav på utlämnande av uppgifter.

9 Avslutande bedömning

Som framgår av redogörelsen ovan är rättsläget oklart när det gäller lagring av sekretessbelagda uppgifter i en publik molntjänst. Den statliga Digitaliseringsutredningen (SOU 2018:25) har så sent som i juli 2018 konstaterat att det är osäkert om sekretessbelagda uppgifter kan lagras externt utan att uppgifterna ska anses röjda.

Först när det kommit rättspraxis i frågan kan VGR och andra myndigheter med säkerhet ta ställning till vilka juridiska regler som gäller vid användning av molntjänster. Sådan rättspraxis kan tillkomma t.ex. genom ett tillsynsbeslut från JO, eller genom en brottmålsprocess avseende sekretessbrott enligt 20 kap. 3 § BrB. Det kan även tänkas att lagstiftaren klargör rättsläget genom ny lagreglering.

I avvaktan på klargörande är det i nuläget fråga om att göra en kvalificerad förhandsbedömning av hur tillsynsmyndigheter och domstolar kommer att se på

användning av molntjänster i offentlig sektor. VGR måste göra en avvägning där fördelarna med molntjänsten vägs mot de risker som finns vid lagring av sekretessbelagd information i molntjänster.

Stora delar av den information som VGR lagrar innehåller sekretessbelagda uppgifter och/eller känsliga personuppgifter. Risken med att anlita externa leverantörer för lagring i molntjänster är att känslig information röjs i sekretesslagstiftningens mening eller hamnar i obehöriga händer.

Mycket talar för att ett röjande i OSL:s mening sker redan genom att en utomstående får tillgång till uppgifterna – oavsett om någon hos leverantören rent faktiskt tagit del av innehållet. Genom att uppgifter lämnas till molntjänst-leverantören, eller dennes underleverantörer, kan informationen falla inom ramen för andra myndigheters rättssystem och därmed finns en risk att andra länders underrättelsetjänster kan begära ut uppgifterna. Så är exempelvis fallet med USA och Cloud Act men det kan vara fallet även i andra länder.

Juridiska enhetens bedömning är att det finns stor risk att sekretessbelagda uppgifter som förs över till en publik molntjänstleverantör kan anses röjda i OSL:s mening.

Som direkt konsekvens av tolkningen av röjandebegreppet följer att JO, Datainspektionen eller annan tillsynsmyndighet kan komma fram till att lagring i molntjänst är otillåten. Det kan då bli mycket tekniskt komplicerat – och kostsamt – att återföra informationen till egen lagring inom VGR. Om Datainspektionen finner att personuppgifter har hanterats i strid mot GDPR finns därtill risken att den beslutar att ta ut sanktionsavgifter. Enskilda personer som anser att deras rättigheter kränkts kan ansöka om skadestånd. Som arkivmyndighet är VGR också skyldig att se till att uppgifter som lagras i moln kan bevaras respektive gallras. Om VGR inte kan säkerställa beständigheten i uppgifterna i molnet strider lagringen sannolikt mot arkiv- och gallringsregler. Slutligen riskerar ansvariga befattningshavare i värsta fall att göra sig skyldiga till sekretessbrott enligt 20 kap. 3 § BrB.

Juridiska enhetens rekommendation utifrån rådande rättsläge är därför att sekretessbelagd/känslig information som utgångspunkt inte ska läggas i publika molntjänster.

För att vara på den säkra sidan bör sekretessbelagd/känslig information i första hand lagras inom VGR:s egen organisation, det vill säga genom att VGR köper och driver/underhåller sina egna servrar.

Undantag kan göras om lagringen av den känsliga informationen sker så att det i **praktiken är osannolikt** att molntjänstleverantören kan ta del av innehållet alternativt tvingas lämna ut informationen till ett annat lands myndigheter. Juridiska enheten kan i dagsläget se två sådana sätt att förhindra detta.

1. Molntjänstleverantören som används är under hela avtalsperioden svensk utan filialer, dotterbolag etc. i annan jurisdiktion samt att deras servrar är placerade i Sverige. Att så är fallet behöver säkerställas genom avtal med leverantören.

2. Kryptering används – så att molntjänstleverantören endast kan läsa informationen i krypterad form. Det vill säga molntjänstleverantören kan i och för sig tvingas att utge information, men den kommer att vara oläslig och därmed inte innebära att sekretessbelagda uppgifter röjs.

Juridiska enheten bedömer att information som omfattas av säkerhetsskyddslagen inte är lämplig att hantera genom en publik molntjänst.

Om kryptering ska ske rekommenderar juridiska enheten att VGR genererar krypteringsnyckeln. Som diskuterats ovan under avsnitt 4.4 kan molntjänstens typ och typen av information som ska lagras påverka vilken sorts krypteringslösning man väljer. En tumregel bör vara att använda en säkrare lösning för sådan data som är extra skyddsvärd – exempelvis uppgifter om hälsa som omfattas både av sekretess enligt OSL samt är en känslig personuppgift enligt GDPR. En effekt av detta kan bli att man får acceptera att den säkra lösningen leder till sämre användarvänlighet.